

BINCOM ACADEMY
5TH CONTACT ASSIGNMENT

AWS IAM PRIVILEGE ESCALATION
ASSESSMENT

IAM Misconfiguration, Controlled Privilege Escalation,
Remediation and Least-Privilege Verification

Prepared By	Oyewumi Yusuf Olayemi
Email	Yusufvic98@gmail.com
Program	BINCOM ACADEMY INTERN
Assessment	5TH CONTACT ASSIGNMENT
Period	SEPTEMBER 2026
Project ID	BINCOM-IAM-001

CONFIDENTIAL — ACADEMIC / AUTHORIZED LABORATORY ASSESSMENT

1. Executive Summary

This report documents an authorized AWS IAM security assessment conducted as part of the BINCOM Academy 5th Contact Assignment. The assessment demonstrates a controlled privilege-escalation path created by an intentionally misconfigured identity-based IAM policy.

A dedicated IAM test identity, BINCOM-IAM-Vulnerable-User, was initially created without permissions. A controlled inline policy was then introduced containing `iam:GetUser`, `iam:ListAttachedUserPolicies` and `iam:AttachUserPolicy`. The critical permission, `iam:AttachUserPolicy`, enabled the test identity to attach the AWS-managed AdministratorAccess policy to itself.

The escalation was independently verified. Remediation removed AdministratorAccess and then removed the simulation inline policy, returning the identity to a zero-permission state. Repeating the exact escalation request after remediation returned AccessDenied. Final verification also showed that `iam:GetUser` was denied.

2. Author and Assessment Information

Field	Value
Prepared By	Oyewumi Yusuf Olayemi
Email	Yusufvic98@gmail.com
Program	BINCOM ACADEMY INTERN
Assessment	5TH CONTACT ASSIGNMENT
Period	SEPTEMBER 2026
Project ID	BINCOM-IAM-001

3. Assignment Objective and Requirements

The supplied assignment requires the demonstration of an IAM misconfiguration and its remediation. The required activities are: create an AWS IAM user with misconfigured permissions; use AWS CLI to attempt privilege escalation; remediate the configuration using the Principle of Least Privilege; and provide IAM configuration screenshots, CLI escalation logs, and documentation of the vulnerability and resolution.

4. Scope, Authorization and Project Continuity

The assessment was conducted within an authorized AWS laboratory environment used for BINCOM project work. The existing PrestaShop-Web-User identity was preserved and was not modified for the privilege-escalation simulation. A separate IAM identity was created solely for this assessment.

Relevant prior BINCOM project work was reused for continuity, including the established AWS/Kali laboratory workflow, AWS CLI configuration, evidence methodology, naming conventions and reporting structure.

5. Lab Environment

Component	Configuration
Testing workstation	Kali Linux virtual machine
Cloud platform	Amazon Web Services (AWS)
AWS service assessed	Identity and Access Management (IAM)
AWS CLI	2.31.12
AWS region	eu-north-1
Existing lab identity	PrestaShop-Web-User
Assessment identity	BINCOM-IAM-Vulnerable-User
AWS CLI profile	bincom-iam

6. Assessment Methodology

1. Establish AWS CLI and IAM baseline.
2. Confirm the existing application identity does not provide IAM administration capability.
3. Create a dedicated IAM test identity with no permissions.
4. Introduce a controlled inline policy containing the privilege-management permission.
5. Verify the resulting authorization state through AWS CLI.
6. Attempt to attach AdministratorAccess to the test identity.
7. Verify successful attachment.
8. Remove AdministratorAccess and the vulnerable simulation policy.
9. Repeat the original escalation request.
10. Verify AccessDenied and the final least-privilege state.

7. Initial IAM Baseline

The AWS CLI baseline confirmed AWS CLI 2.31.12, the eu-north-1 region and authentication through the existing PrestaShop-Web-User lab identity. IAM enumeration operations against that identity returned AccessDenied. This established a controlled starting point and avoided using the previous application identity as the assessment subject.

8. Vulnerable IAM Configuration

BINCOM-IAM-Vulnerable-User was created without console access and without attached permission policies. A customer inline policy named BINCOM-IAM-PrivilegeEscalation-Simulation was then introduced for the controlled demonstration.

The simulation policy granted iam:GetUser, iam:ListAttachedUserPolicies and iam:AttachUserPolicy. The security-relevant permission was iam:AttachUserPolicy. AWS documentation identifies policy-attachment permissions such as AttachUserPolicy as sensitive because they can allow a principal to grant permissions through managed policies when not appropriately restricted.

9. Privilege-Escalation Simulation

Using the bincom-iam AWS CLI profile, the test identity executed the following request:

```
aws iam attach-user-policy \ --user-name BINCOM-IAM-Vulnerable-User \ --policy-arn
arn:aws:iam::aws:policy/AdministratorAccess \ --profile bincom-iam
```

The command completed without an authorization error. A subsequent IAM query confirmed that AdministratorAccess was attached to the test identity. This establishes the privilege-escalation path under the intentionally vulnerable configuration.

10. Security Impact and Finding

Attribute	Assessment
Affected identity	BINCOM-IAM-Vulnerable-User
Root cause	iam:AttachUserPolicy was granted to the test identity
Observed escalation	AdministratorAccess attached to the same identity
Security effect	Unauthorized expansion of the identity's effective permissions
Evidence	E06–E09

This is a laboratory security finding and is not represented as a public CVE or externally disclosed vulnerability. The report uses current AWS IAM security guidance to validate the control objective and remediation approach.

11. Remediation — Principle of Least Privilege

Remediation was performed in two stages. First, the AdministratorAccess policy was removed. Second, the BINCOM-IAM-PrivilegeEscalation-Simulation inline policy was removed completely because the test identity had no legitimate

IAM administration requirement.

The resulting IAM user state showed zero attached permission policies. This removed the escalation mechanism rather than merely removing the administrative privilege gained during the demonstration.

12. Post-Remediation Verification

The exact AttachUserPolicy request used during exploitation was repeated after remediation. AWS returned AccessDenied and reported that no identity-based policy allowed iam:AttachUserPolicy. A final iam:GetUser request also returned AccessDenied, while sts:GetCallerIdentity continued to identify the same test identity.

This before/after retest provides direct evidence that the escalation path was available during the vulnerable configuration and unavailable after remediation.

13. Current Vulnerability-Reporting Alignment

The report structure was cross-checked against current AWS IAM security guidance and recent vulnerability/remediation reporting practices. AWS's current IAM guidance emphasizes least privilege, policy validation with IAM Access Analyzer, regular review and removal of unused permissions, and restrictions around permissions-management actions. AWS Security Hub guidance also describes direct policy escalation paths as an IAM exposure pattern and recommends removing unnecessary privileges and reducing the blast radius.

The report therefore uses a contemporary finding structure: affected identity, root cause, observed impact, evidence, remediation, and post-remediation verification. CISA's current remediation guidance similarly emphasizes permanent configuration changes, mitigation and tracking remediation status.

14. Remediation Recommendations

- Grant only the IAM actions required for a defined business or laboratory function.
- Do not grant AttachUserPolicy, PutUserPolicy, CreatePolicy, or equivalent permissions to identities that do not require IAM administration.
- Where policy attachment is legitimately required, restrict which principals and managed policies may be affected and apply conditions where appropriate.
- Use IAM Access Analyzer to validate policies and identify opportunities to reduce permissions.
- Regularly review unused IAM users, credentials and permissions and remove them when no longer required.
- Prefer temporary credentials and role-based access patterns for human and workload access where appropriate.
- Use permissions boundaries or organization-level guardrails where delegated IAM administration is necessary.

15. Findings Summary

Finding	Root Cause	Evidence	Resolution
IAM privilege-escalation path	Excessive iam:AttachUserPolicy permissions	E00–E09	AdministratorAccess removed; vulnerable inline policy removed; E12–E13 confirm deni

16. Evidence Register

ID	Evidence	Purpose
E01	AWS CLI Environment Baseline	AWS CLI 2.31.12 and the original PrestaShop-Web-User lab identity are confirmed.
E02	Existing IAM User Permission Baseline	IAM enumeration against PrestaShop-Web-User returns AccessDenied.
E03	AWS IAM Administrative Lab Environment	Authorized IAM console environment used for controlled setup/remediation.
E04	Dedicated Vulnerable IAM User — Initial Zero-Permissions State	bincom-iam-Vulnerable-User is shown with no attached permissions.
E05	Vulnerable User CLI Authentication and Pre-Misconfiguration Baseline	The bincom-iam-Vulnerable-User authenticates through the bincom-iam CLI profile and initially lacks iam:GetUser.
E06	Intentional IAM Privilege-Escalation Misconfiguration	The controlled inline simulation policy is attached.
E07	Post-Misconfiguration IAM Permission Verification	iam:GetUser succeeds after the simulation policy is introduced.
E08	Privilege Escalation Attempt	The test identity invokes iam:AttachUserPolicy for AdministratorAccess.

ID	Evidence	Purpose
E09	Privilege Escalation Verification	AdministratorAccess is confirmed as attached to the test identity.
E10	Removal of Excessive Administrator Privilege	AdministratorAccess is removed.
E11	Least-Privilege IAM Remediation	The vulnerable inline policy is removed; permission policies are zero.
E12	Post-Remediation Privilege-Escalation Test	The same escalation command returns AccessDenied.
E13	Final Post-Remediation IAM Verification	The identity remains present while iam:GetUser is denied.

17. Conclusion

The AWS IAM assessment successfully demonstrated a controlled privilege-escalation scenario caused by an excessive policy-management permission. The test identity used iam:AttachUserPolicy to attach AdministratorAccess to itself, and the resulting attachment was independently verified.

The vulnerability was remediated by removing AdministratorAccess and the simulation inline policy. Repeating the original escalation request resulted in AccessDenied, and final authorization testing confirmed that the simulation permissions were no longer available. The evidence therefore supports the conclusion that the demonstrated escalation path was eliminated through least-privilege remediation.

18. References

- AWS IAM Security Best Practices — least privilege, policy validation, unused permission review and guardrails.
- AWS IAM Policies and Permissions — least privilege and controls for policy-attachment permissions.
- AWS IAM Security Audit Guide — review of excessive permissions and sensitive policy-management actions.
- AWS Security Hub — IAM user exposure/remediation guidance for direct policy escalation paths.
- CISA Cybersecurity Incident and Vulnerability Response Playbooks — remediation and tracking principles.

Appendix A — Evidence Screenshots

Evidence E01–E13 is presented chronologically. Credentials and secrets are not intentionally reproduced.

E01 — AWS CLI Environment Baseline

AWS CLI 2.31.12 and the original PrestaShop-Web-User lab identity are confirmed.

```
(kali㉿kali)-[~]
$ aws --version
aws-cli/2.31.35 Python/3.13.12 Linux/6.18.12+kali-amd64 source/x86_64.kali.2026

(kali㉿kali)-[~]
$ which aws
/usr/bin/aws

(kali㉿kali)-[~]
$ aws configure list
NAME                : VALUE                                : TYPE                : LOCATION
profile             : <not set>                          : None                : None
access_key          : *****ZB63                        : shared-credentials-file :
secret_key          : *****wjln                        : shared-credentials-file :
region              : eu-north-1                         : config-file         : ~/.aws/config

(kali㉿kali)-[~]
$ aws sts get-caller-identity
{
  "UserId": "AIDA2EMXIGUMC073IRY2S",
  "Account": "696638780696",
  "Arn": "arn:aws:iam::696638780696:user/PrestaShop-Web-User"
}
```

Evidence E01: AWS CLI Environment Baseline

E02 — Existing IAM User Permission Baseline

IAM enumeration against PrestaShop-Web-User returns AccessDenied.

```
(kali@kali)-[~]
$ aws iam get-user

An error occurred (AccessDenied) when calling the GetUser operation: User: arn:aws:iam::696638780696:user/PrestaShop-Web-User is not a
uthorized to perform: iam:GetUser on resource: user PrestaShop-Web-User because no identity-based policy allows the iam:GetUser action
. Go to https://us-east-1.console.aws.amazon.com/iam/home?region=us-east-1#/authorization-details/9z2w4g8pt5amgmejfu43p27v3 for comple
te details, or call the GetRequestAuthorizationDetails API with the following authorization id: 9z2w4g8pt5amgmejfu43p27v3

(kali@kali)-[~]
$ aws iam list-attached-user-policies --user-name PrestaShop-Web-User

An error occurred (AccessDenied) when calling the ListAttachedUserPolicies operation: User: arn:aws:iam::696638780696:user/PrestaShop-Web-User is not aut
horized to perform: iam:ListAttachedUserPolicies on resource: user PrestaShop-Web-User because no identity-based policy allows the iam:ListAttachedUserPo
licies action. Go to https://us-east-1.console.aws.amazon.com/iam/home?region=us-east-1#/authorization-details/8ukmvo847modhghj9af4nvdsp for complete det
ails, or call the GetRequestAuthorizationDetails API with the following authorization id: 8ukmvo847modhghj9af4nvdsp

(kali@kali)-[~]
$ aws iam list-user-policies --user-name PrestaShop-Web-User

An error occurred (AccessDenied) when calling the ListUserPolicies operation: User: arn:aws:iam::696638780696:user/PrestaShop-Web-User is not authorized
to perform: iam:ListUserPolicies on resource: user PrestaShop-Web-User because no identity-based policy allows the iam:ListUserPolicies action. Go to htt
ps://us-east-1.console.aws.amazon.com/iam/home?region=us-east-1#/authorization-details/c2yqw3xk73rwyvoi4u24gzhu for complete details, or call the GetReq
uestAuthorizationDetails API with the following authorization id: c2yqw3xk73rwyvoi4u24gzhu

(kali@kali)-[~]
$ aws iam list-groups-for-user --user-name PrestaShop-Web-User

An error occurred (AccessDenied) when calling the ListGroupsForUser operation: User: arn:aws:iam::696638780696:user/PrestaShop-Web-User is not authorized
to perform: iam:ListGroupsForUser on resource: user PrestaShop-Web-User because no identity-based policy allows the iam:ListGroupsForUser action. Go to ht
tps://us-east-1.console.aws.amazon.com/iam/home?region=us-east-1#/authorization-details/2jwtfllj95b6jr10d8pz3gxdv for complete details, or call the Get
RequestAuthorizationDetails API with the following authorization id: 2jwtfllj95b6jr10d8pz3gxdv

(kali@kali)-[~]
$ aws iam list-user-tags --user-name PrestaShop-Web-User

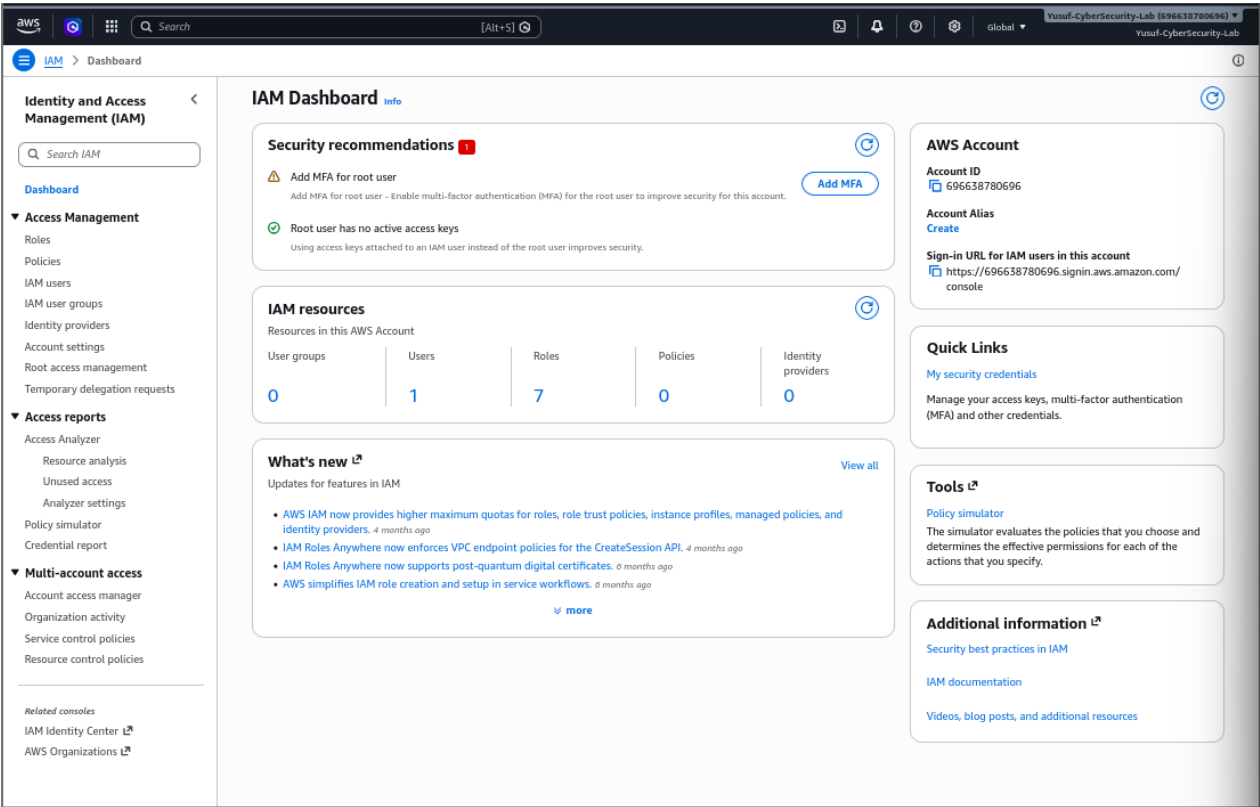
An error occurred (AccessDenied) when calling the ListUserTags operation: User: arn:aws:iam::696638780696:user/PrestaShop-Web-User is not authorized to p
erform: iam:ListUserTags on resource: user PrestaShop-Web-User because no identity-based policy allows the iam:ListUserTags action. Go to https://us-east
-1.console.aws.amazon.com/iam/home?region=us-east-1#/authorization-details/4plw9oo136k4rbc5j0p5oxuwt for complete details, or call the GetRequestAuthoriz
ationDetails API with the following authorization id: 4plw9oo136k4rbc5j0p5oxuwt

(kali@kali)-[~]
$
```

Evidence E02: Existing IAM User Permission Baseline

E03 — AWS IAM Administrative Lab Environment

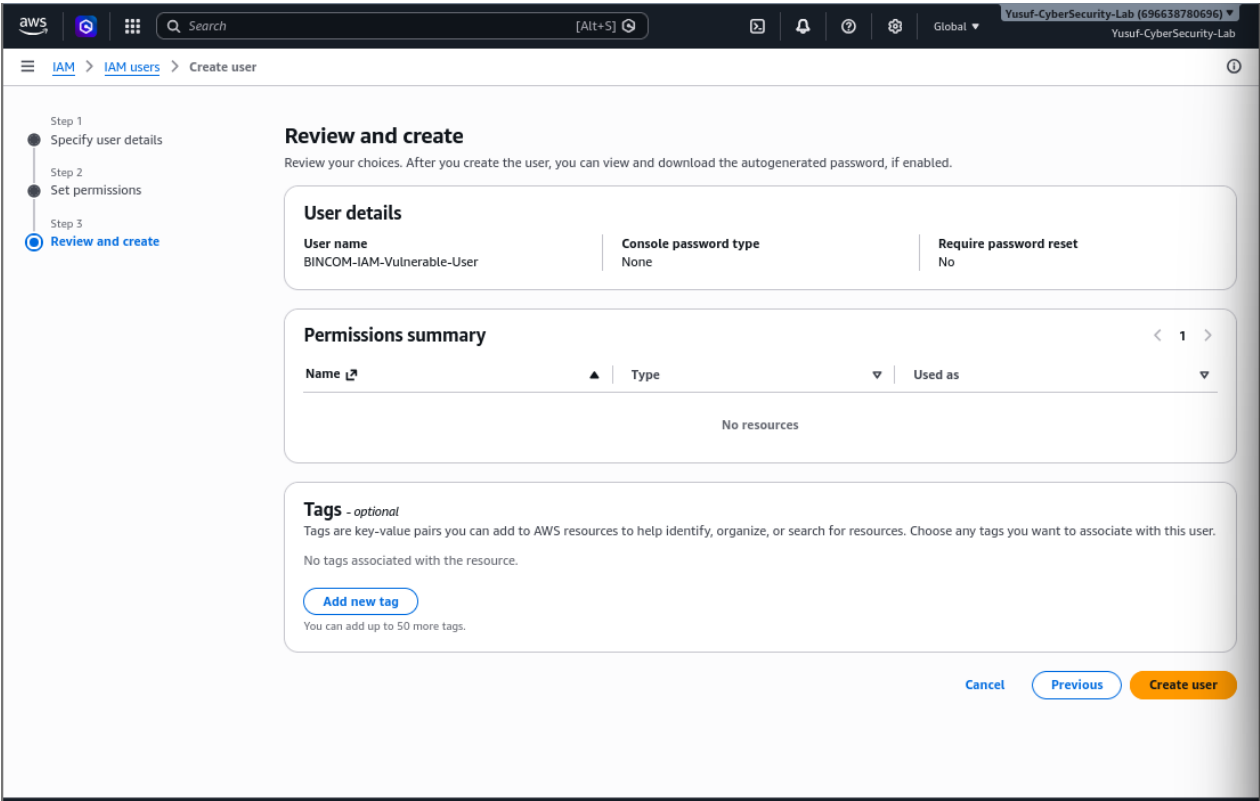
Authorized IAM console environment used for controlled setup/remediation.



Evidence E03: AWS IAM Administrative Lab Environment

E04 — Dedicated Vulnerable IAM User — Initial Zero-Permission State

BINCOM-IAM-Vulnerable-User is shown with no attached permissions.



Evidence E04: Dedicated Vulnerable IAM User — Initial Zero-Permission State

E05 — Vulnerable User CLI Authentication and Pre-Misconfiguration Baseline

The dedicated user authenticates through the bincom-iam CLI profile and initially lacks iam:GetUser.

```
(kali@kali)-[~]
$ aws sts get-caller-identity --profile bincom-iam
{
  "UserId": "AIDA2EMXIGUMPUSBZIYXY",
  "Account": "696638780696",
  "Arn": "arn:aws:iam::696638780696:user/BINCOM-IAM-Vulnerable-User"
}

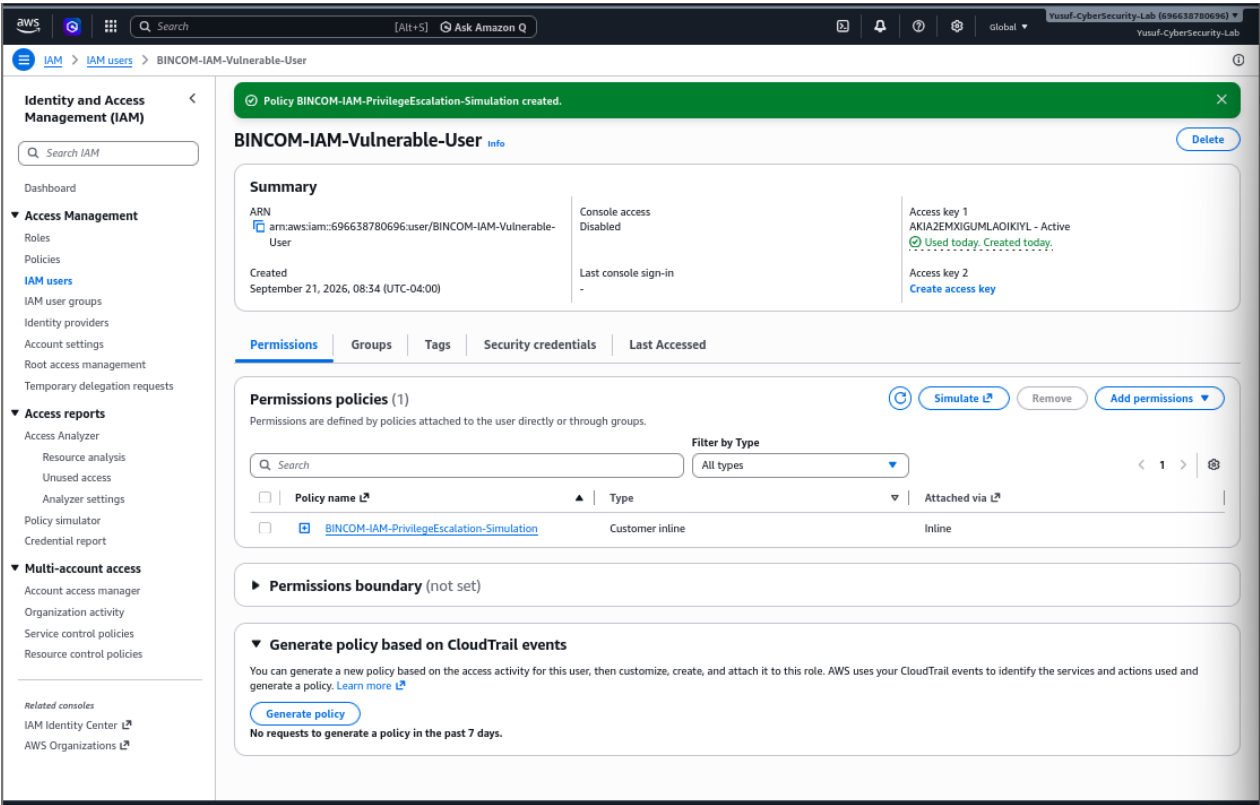
(kali@kali)-[~]
$ aws iam get-user --user-name BINCOM-IAM-Vulnerable-User --profile bincom-iam
An error occurred (AccessDenied) when calling the GetUser operation: User: arn:aws:iam::696638780696:user/BINCOM-IAM-Vulnerable-User is not authorized to perform: iam:GetUser on resource: user BINCOM-IAM-Vulnerable-User because no identity-based policy allows the iam:GetUser action. Go to https://us-east-1.console.aws.amazon.com/iam/home?region=us-east-1#/authorization-details/6n2uy7unzrr7tfloxbbstmhrx for complete details, or call the GetRequestAuthorizationDetails API with the following authorization id: 6n2uy7unzrr7tfloxbbstmhrx

(kali@kali)-[~]
$
```

Evidence E05: Vulnerable User CLI Authentication and Pre-Misconfiguration Baseline

E06 — Intentional IAM Privilege-Escalation Misconfiguration

The controlled inline simulation policy is attached.



Evidence E06: Intentional IAM Privilege-Escalation Misconfiguration

E07 — Post-Misconfiguration IAM Permission Verification

iam:GetUser succeeds after the simulation policy is introduced.

The screenshot displays a terminal window on the left and the AWS IAM console on the right. The terminal shows the following commands and their outputs:

```
(kali@kali)-[~]
$ aws iam get-user \
  --user-name BINCOM-IAM-Vulnerable-User \
  --profile bincom-iam
{
  "User": {
    "Path": "/",
    "UserName": "BINCOM-IAM-Vulnerable-User",
    "UserId": "AIDA2EMXIGUMPUSBZIYXY",
    "Arn": "arn:aws:iam::696638780696:user/BINCOM-IAM-Vulnerable-User",
    "CreateDate": "2026-09-21T12:34:39+00:00"
  }
}

(kali@kali)-[~]
$ aws iam list-attached-user-policies \
  --user-name BINCOM-IAM-Vulnerable-User \
  --profile bincom-iam
{
  "AttachedPolicies": []
}

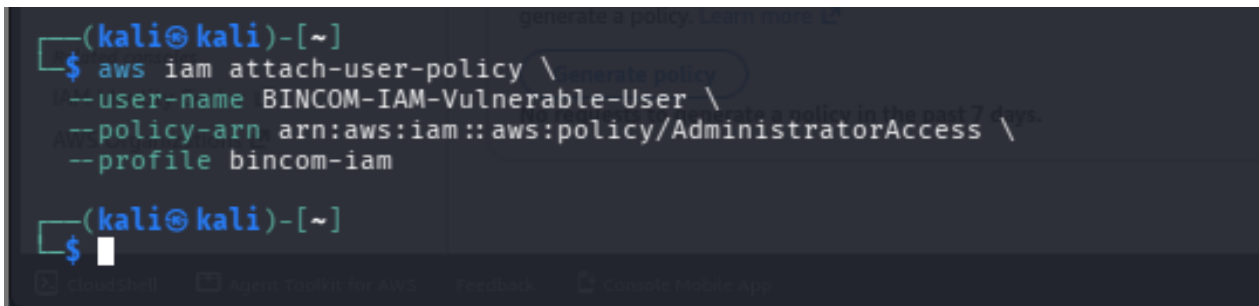
(kali@kali)-[~]
$ aws sts get-caller-identity \
  --profile bincom-iam
{
  "UserId": "AIDA2EMXIGUMPUSBZIYXY",
  "Account": "696638780696",
  "Arn": "arn:aws:iam::696638780696:user/BINCOM-IAM-Vulnerable-User"
}
```

The AWS IAM console on the right shows the 'Permissions' tab for the user 'BINCOM-IAM-Vulnerable-User'. It lists one policy: 'BINCOM-IAM-PrivilegeEscalation-Simulation' of type 'Customer inline'. The 'Permissions boundary' is set to '(not set)'. There is also a section for 'Generate policy based on CloudTrail events'.

Evidence E07: Post-Misconfiguration IAM Permission Verification

E08 — Privilege Escalation Attempt

The test identity invokes iam:AttachUserPolicy for AdministratorAccess.

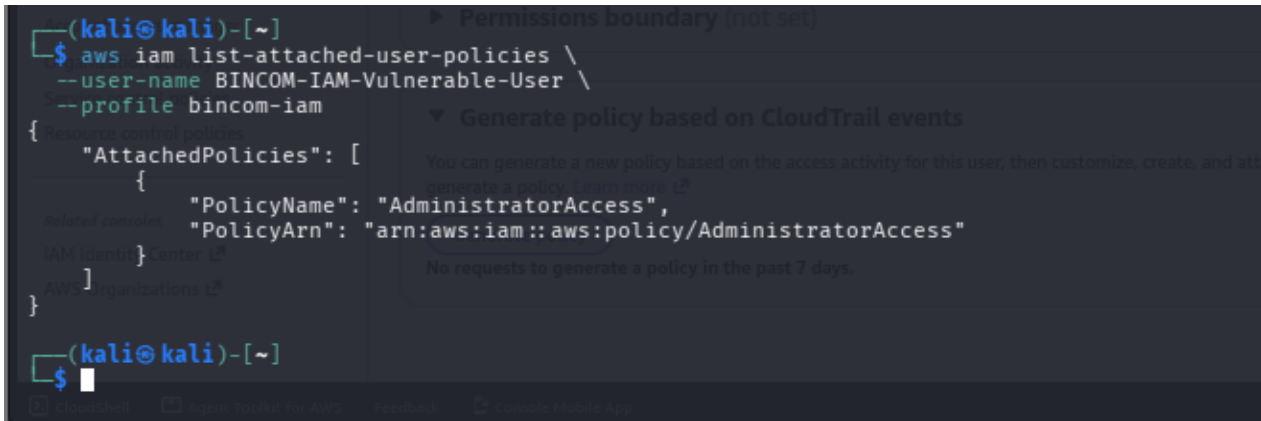


```
(kali㉿kali)-[~]  
$ aws iam attach-user-policy \generate policy  
--user-name BINCOM-IAM-Vulnerable-User \generate a policy in the past 7 days.  
--policy-arn arn:aws:iam::aws:policy/AdministratorAccess \  
--profile bincom-iam  
  
(kali㉿kali)-[~]  
$
```

Evidence E08: Privilege Escalation Attempt

E09 — Privilege Escalation Verification

AdministratorAccess is confirmed as attached to the test identity.

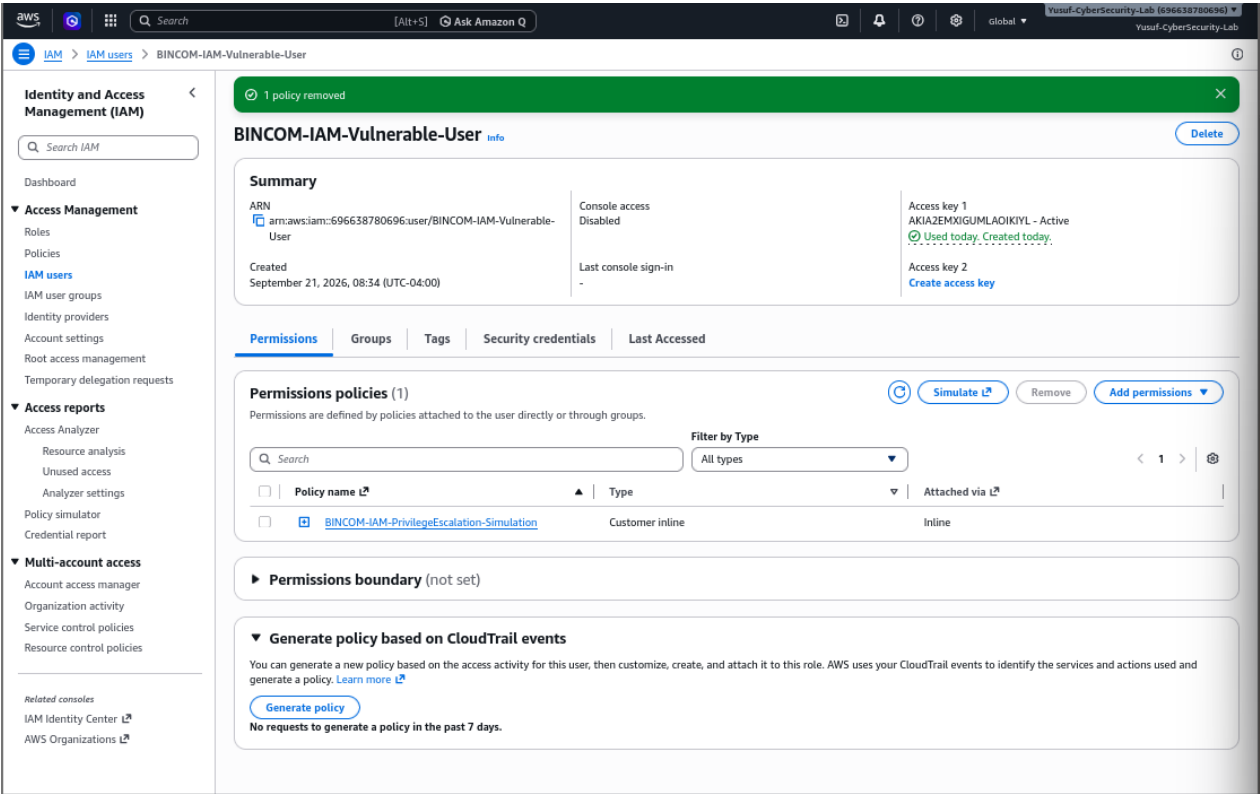


```
(kali㉿kali)-[~]
$ aws iam list-attached-user-policies \
  --user-name BINCOM-IAM-Vulnerable-User \
  --profile bincom-iam
{
  "AttachedPolicies": [
    {
      "PolicyName": "AdministratorAccess",
      "PolicyArn": "arn:aws:iam::aws:policy/AdministratorAccess"
    }
  ]
}
```

Evidence E09: Privilege Escalation Verification

E10 — Removal of Excessive Administrator Privilege

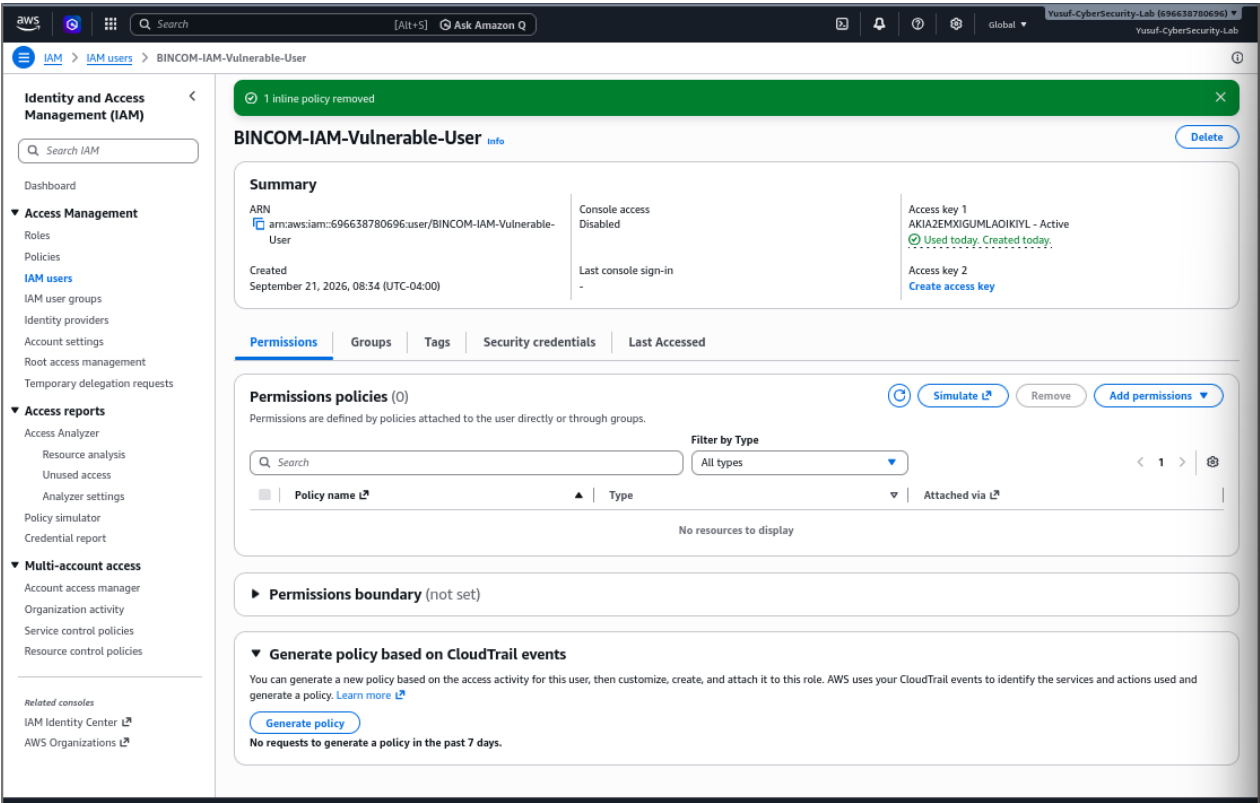
AdministratorAccess is removed.



Evidence E10: Removal of Excessive Administrator Privilege

E11 — Least-Privilege IAM Remediation

The vulnerable inline policy is removed; permission policies are zero.



Evidence E11: Least-Privilege IAM Remediation

E12 — Post-Remediation Privilege-Escalation Test

The same escalation command returns AccessDenied.

```
(kali@kali)-[~]
$ aws iam attach-user-policy \
  --user-name BINCOM-IAM-Vulnerable-User \
  --policy-arn arn:aws:iam::aws:policy/AdministratorAccess \
  --profile bincom-iam
An error occurred (AccessDenied) when calling the AttachUserPolicy operation: User: arn:aws:iam::696638780696:user/BINCOM-IAM-Vulnerable-User is not authorized to perform: iam:AttachUserPolicy on resource: user BINCOM-IAM-Vulnerable-User because no identity-based policy allows the iam:AttachUserPolicy action
(kali@kali)-[~]
$
```

Evidence E12: Post-Remediation Privilege-Escalation Test

E13 — Final Post-Remediation IAM Verification

The identity remains present while iam:GetUser is denied.

```
(kali@kali)-[~]
$ aws sts get-caller-identity --profile bincom-iam
{
  "UserId": "AIDA2EMXIGUMPUSBZIYXY",
  "Account": "696638780696",
  "Arn": "arn:aws:iam::696638780696:user/BINCOM-IAM-Vulnerable-User"
}

(kali@kali)-[~]
$ aws iam get-user \
  --user-name BINCOM-IAM-Vulnerable-User \
  --profile bincom-iam
An error occurred (AccessDenied) when calling the GetUser operation: User: arn:aws:iam::696638780696:user/BINCOM-IAM-Vulnerable-User is not authorized to perform: iam:GetUser on resource: user BINCOM-IAM-Vulnerable-User because no identity-based policy allows the iam:GetUser action. Go to https://us-east-1.console.aws.amazon.com/iam/home?region=us-east-1#/authorization-details/17x99u44e6p5rcppzuvz951w2 for complete details, or call the GetRequestAuthorizationDetails API with the following authorization id: 17x99u44e6p5rcppzuvz951w2

(kali@kali)-[~]
$
```

Evidence E13: Final Post-Remediation IAM Verification